Figure 15.3 shows how these policies are organized into three layers. Foundational security policies set enterprise-wide requirements that apply to all systems, no matter who makes the request or which service is involved. Shared operational policies include rules that cover multiple systems or workflows and are owned by the groups responsible for those domains—for example, deployment rules for engineering or reporting controls for finance. Application policies define the service-specific authorization logic for individual applications. These layers vary in scope and ownership, but they work together: Foundational policies establish the organization's core requirements; shared operational policies reflect cross-system or departmental rules; and application policies control each service's behavior.

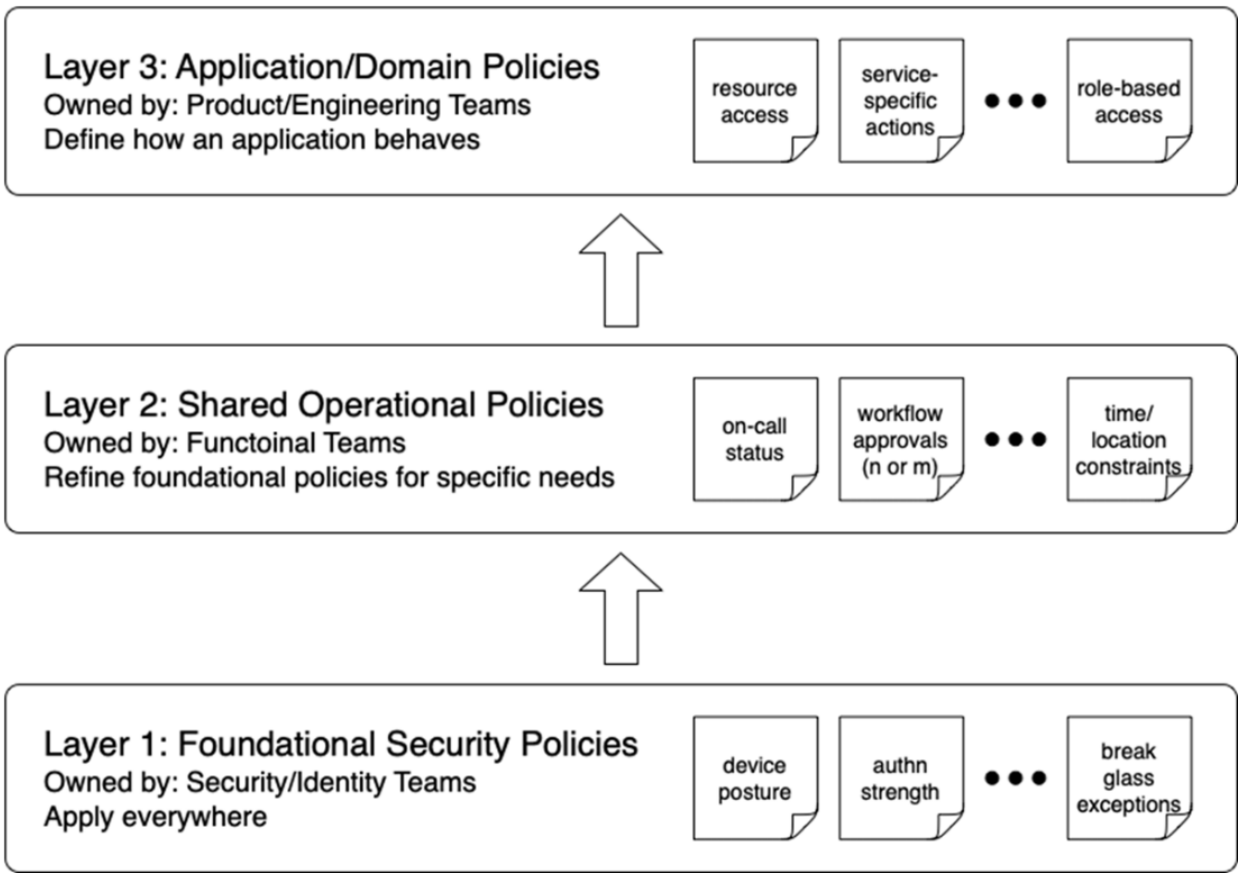


Figure 15.3 Zero-trust authorization is based on layered policies. Foundational security policies define enterprise-wide requirements. Shared operational policies capture rules owned by functional groups and applied across multiple systems or workflows. Application policies define service-specific authorization logic. These layers differ in scope and ownership but are evaluated together to produce a unified authorization decision.